Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA)

List of teammates :

S.no	Name	Collage name	Contact
1	Vismaya M	Pollachi collage of arts and science,Poosaripatti.	6369854850
2	Shanmugapriya G	Pollachi collage of arts and science ,Poosaripatti.	7339022592
3	Yogeshwari R	Pollachi collage of arts and science,Poosaripatti.	9384149605

4	Vignesh M	Pollachi collage of arts and science,Poosaripatti.	8848104820

Project Title

Enforce Least-Privilege Access through Identity-Aware, Application-Specific Access Policies using Zscaler Private Access (ZPA)

Abstract

With the increasing number of cyber threats and remote access requirements, organizations need stronger security mechanisms to protect internal applications and sensitive data. Traditional network security models often rely on perimeter-based defenses, which may allow excessive access once a user is authenticated. This project focuses on implementing a secure access model based on the principle of least privilege using Zscaler Private Access.
The solution uses identity verification, device posture validation, and context-aware access control to ensure that users can only access the applications necessary for their role. By applying the Zero Trust approach, the project improves security, reduces unauthorized access, and protects critical organizational resources.

Introduction

Modern organizations rely heavily on web applications and cloud services to support their operations. However, traditional access solutions such as Virtual Private Network often provide broad network access once users are authenticated. This increases the risk of data breaches and lateral movement within the network if an attacker gains access.
To address these issues, organizations are adopting the Zero Trust security model, which verifies every user and device before granting access to applications. Zscaler Private Access (ZPA) enables secure application access without exposing the internal network to the internet. It provides application-level connectivity based on identity, device posture, and contextual factors. This project demonstrates how ZPA can enforce identity-aware access policies and implement leastprivilege principles to improve cybersecurity posture and protect organizational resources.

Use Case Scenarios and Output

Use Case Scenario 1: Secure User Authentication

Users attempt to access internal applications through the ZPA platform.

Output:

Only authenticated users with valid credentials are granted access to the requested application.

Use Case Scenario 2: Device Security Verification

The system checks whether the user's device meets security compliance requirements before granting access. Output:

Access is granted only to secure and compliant devices, while insecure devices are restricted.

Use Case Scenario 3: Application-Specific Access

Users are provided access only to applications relevant to their role within the organization.

Output:

Unauthorized applications remain hidden and inaccessible to users without proper permissions.

Use Case Scenario 4: Context-Aware Access Control

The system evaluates contextual factors such as user location, device type, and login behavior.

Output:

Suspicious login attempts are detected and blocked, preventing unauthorized access.

Use Case Scenario 5: Continuous Security Monitoring

User activity and access requests are monitored for potential security threats.

Output:

Security administrators can track access logs, detect unusual activity, and respond quickly to security incidents.

Stage 1: Title:

owasp to 10

Overview:

The OWASP Top 10 is a widely recognized document that highlights the most critical security risks affecting web applications. It is published by the Open Worldwide Application Security Project, a global non-profit organization dedicated to improving the security of software. The OWASP Top 10 provides developers, security professionals, and organizations with awareness about common vulnerabilities so they can design and maintain more secure web applications.

The primary goal of the OWASP Top 10 is to educate developers and organizations about major web security risks and encourage the adoption of secure coding practices. By understanding these vulnerabilities, developers can reduce the chances of attackers exploiting weaknesses in web applications. The document also serves as a baseline standard for web application security testing and auditing.

The OWASP Top 10 is updated periodically based on industry research, vulnerability data, and contributions from security experts worldwide. Each update reflects the evolving landscape of cybersecurity threats and modern web technologies. The most recent version, OWASP Top 10 (2021 Edition), identifies the most significant risks currently faced by web applications.

The list includes vulnerabilities such as Broken Access Control, Cryptographic Failures, Injection attacks, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, and Server-Side Request Forgery (SSRF). These vulnerabilities can lead to serious consequences including data breaches, unauthorized access, system compromise, and loss of sensitive information.

Organizations across the world use the OWASP Top 10 as a guideline for secure software development, penetration testing, and security awareness training. It helps teams prioritize security risks and focus on the most dangerous vulnerabilities during the development lifecycle. Many security frameworks and compliance programs also reference the OWASP Top 10 as an important benchmark for application security.

In summary, the OWASP Top 10 plays a crucial role in raising awareness about web application security risks and promoting best practices to protect modern applications from cyber attacks. By following its recommendations, developers and organizations can significantly improve the security and reliability of their web systems

List of Vuinerability Table:

S.no	Vuinerability name	CWE/CVE no.
	Absolute Path Traversal	CWE 36

	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE 614
	Use of Unmaintained Third Party Components	CWE 1104

Report:

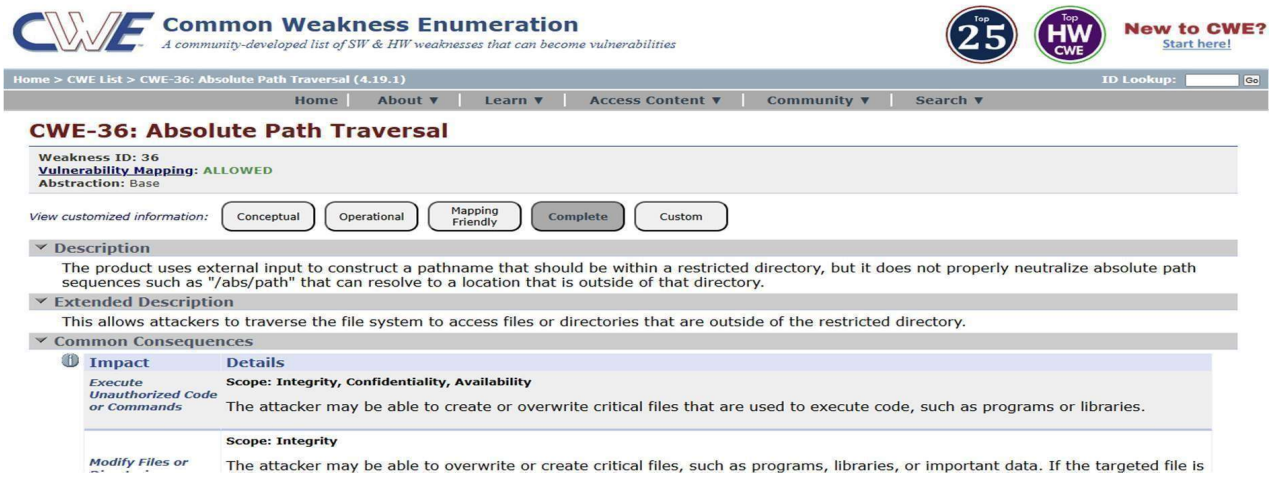
1)Vulnerability name Absolute Path Traversal

Cwe/Cve number: CWE 36

Owasp category:ADI:2025 Broken Access Control Description: In many web applications, files such as images, documents, or configuration files are retrieved using parameters provided in the URL or user input. If the application directly uses these inputs without sanitization, an attacker may supply an absolute file path (for example /etc/passwd or C:\Windows\system.ini). This allows the attacker to bypass normal access restrictions and retrieve sensitive files from the server.

Absolute Path Traversal differs from relative path traversal because the attacker provides the full system path instead of using directory traversal sequences like ../.

Business import: The CWE-36: Absolute Path Traversal vulnerability allows attackers to access sensitive server files. This can lead to data leakage, system compromise, and reputational damage, and is related to Broken Access Control in OWASP Top 10 (2021 Edition).



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-36: Absolute Path Traversal (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-36: Absolute Path Traversal

Weakness ID: 36
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Extended Description

This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

Common Consequences

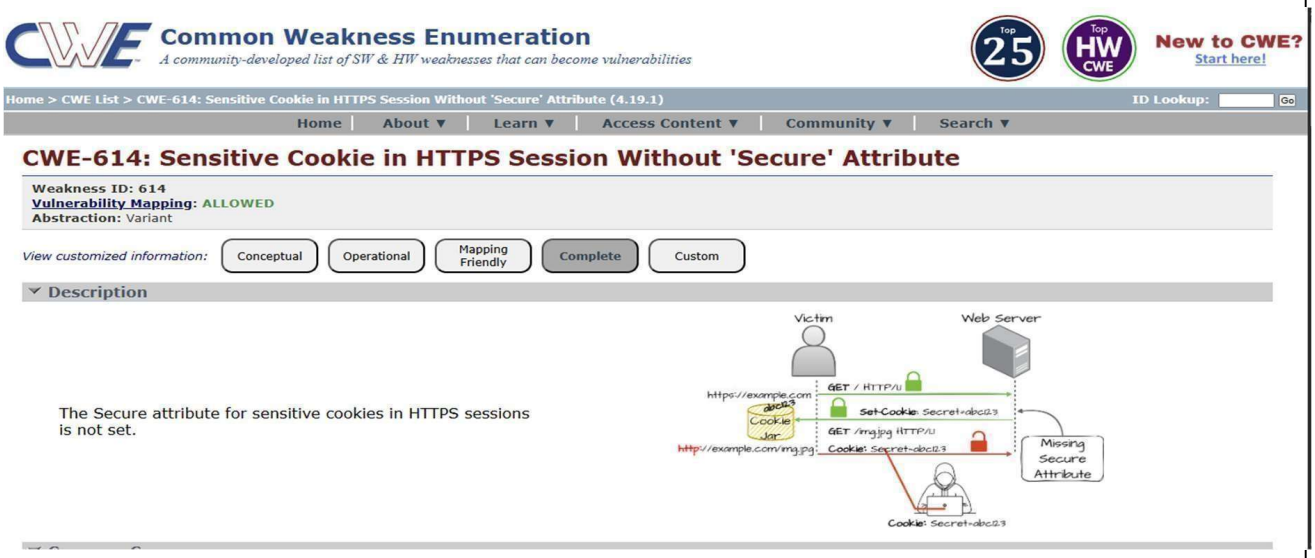
Impact	Details
Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability** The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries.
Modify Files or	**Scope: Integrity** The attacker may be able to overwrite or create critical files, such as programs, libraries, or important data. If the targeted file is

2) Vulnerability name: Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

Cwe/Cve number: CWE 614

Owasp category: A02:2025 Security Misconfiguration
Description: This vulnerability occurs when a web application sets a sensitive cookie without the Secure attribute. Without this attribute, the browser may send the cookie over unencrypted HTTP connections, even if the session was originally established over HTTPS. This can allow attackers to intercept the cookie through network attacks and potentially hijack user sessions.

Business import: Attackers may steal session cookies and gain unauthorized access to user accounts, leading to data exposure, account compromise, and reputational damage for the organization

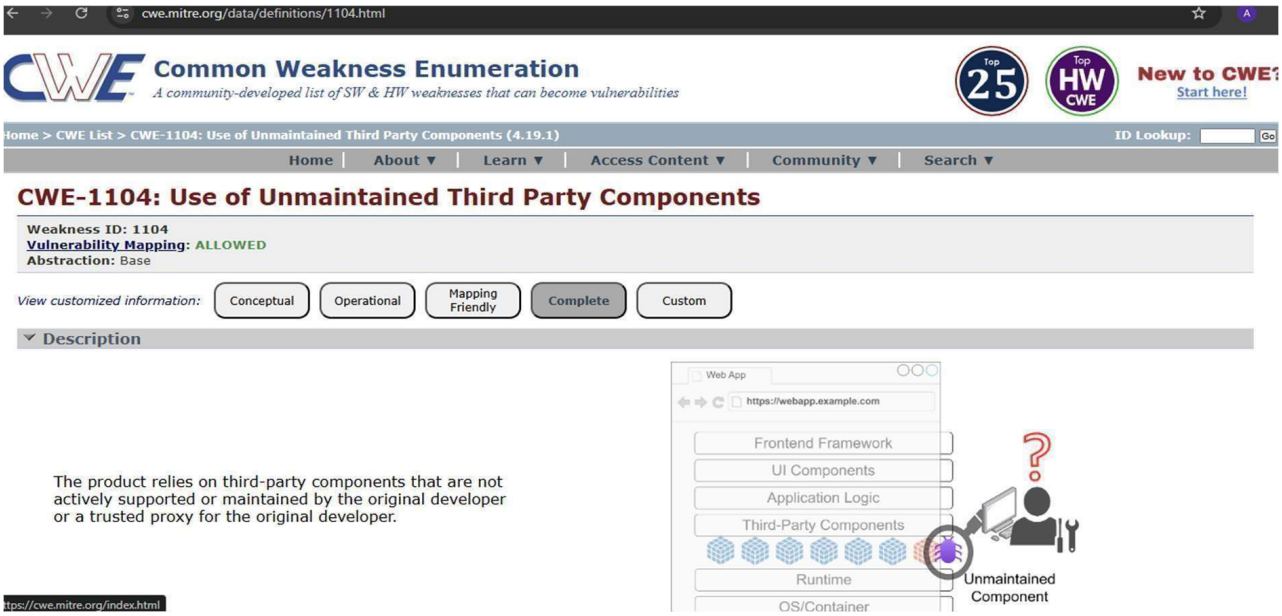


3) Vuinerability name: Use of Unmaintained Third Party Components

Cwe/Cve number: CWE 1104

Owasp category: A03:2025 Software Supply Chain Failures
Description: This vulnerability occurs when an application uses third-party libraries or components that are no longer maintained or updated. These components may contain known security vulnerabilities that will not be fixed by the developers, making the application more vulnerable to attacks.

Business import: Attackers can exploit known vulnerabilities in outdated components, leading to system compromise, data breaches, and security risks for the organization.


cwe.mitre.org/data/definitions/1104.html
Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities
Top 25
Top HW CWE
New to CWE?
Start here!
Home > CWE List > CWE-1104: Use of Unmaintained Third Party Components (4.19.1)
ID Lookup:
Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾
CWE-1104: Use of Unmaintained Third Party Components
Weakness ID: 1104
Vulnerability Mapping: ALLOWED
Abstraction: Base
View customized information:
Conceptual
Operational
Mapping Friendly
Complete
Custom
Description
The product relies on third-party components that are not actively supported or maintained by the original developer or a trusted proxy for the original developer.
Web App
https://webapp.example.com
Frontend Framework
UI Components
Application Logic
Third-Party Components
Runtime
OS/Container
Unmaintained Component
https://cwe.mitre.org/index.html

Stage 2:

Title: Nessus scan

Overview: Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices. ● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional

List of Vuinerability Table:

S.No	Vulnerability Name	Severity	Plugin ID
1	Traceroute Information	INFO	10287
2	TLS Version 1.2 Protocol Detection	INFO	136318
3	TLS ALPN Supported Protocol Enumeration	INFO	84821
4	TCP/IP Timestamps Supported	INFO	25220
5	Strict Transport Security (STS) Detection	INFO	42822

6	SSL Root Certification Authority Certificate Information	INFO	94761
7	SSL Certificate Chain Contains Certificates Expiring Soon	INFO	83298
8	Shor's Harvest Now Decrypt Later	INFO	298387
9	Service Detection	INFO	22964
10	Remote Services Not Using PostQuantum Ciphers	INFO	277650

11	OS Fingerprints Detected	INFO	209654
12	Nessus SYN Scanner Detection	INFO	11219
13	Nessus Scan Information	INFO	19506
14	Host Fully Qualified Domain Name (FQDN) Resolution	INFO	12053
15	Additional DNS Hostnames	INFO	46180
16	SSL Perfect Forward Secrecy Cipher Suites Supported	INFO	57041

17	SSL Cipher Suites Supported	INFO	21643
18	SSL Cipher Block Chaining Cipher Suites Supported	INFO	70544
19	SSL Certificate Information	INFO	10863
20	SSL Certificate Expiry – Future Expiry	INFO	42981
21	SSL / TLS Versions Supported	INFO	56984
22	SSL/TLS Recommended Cipher Suites	INFO	156899

23	TLS Supported Groups	INFO	277654
24	Web Server No 404 Error Code Check	INFO	10386
25	Web Server robots.txt Information Disclosure	INFO	10302
26	HTTP Server Type and Version Disclosure	INFO	10107
27	HyperText Transfer Protocol (HTTP) Information	INFO	24260

Target Website: www.hackthissite.org

Target IP Address: IPv4 Address: 137.74.187.100, 137.74.187.102

137.74.187.103

137.74.187.101

137.74.187.104

Report:

1. Vulnerability Name: Traceroute Information
Severity: INFO
Plugin: 10287

Description:

The scan performs a traceroute to the target host to identify the network path between the scanner and the target system, revealing intermediate routers and network devices.

Solution:
Disable or restrict traceroute/ICMP responses using firewall rules.

Business Impact:

This may expose network structure and routing information that attackers could use for reconnaissance and planning targeted attacks.

2. Vulnerability Name: 136318-TLS Version 1.2 Protocol Detection

PSeverity: INFO

Plugin: 136318

Description: The scan detected that the server supports Transport Layer Security (TLS) 1.2, which provides encrypted communication between the client and server.

Solution: Ensure TLS 1.2 or higher (such as TLS 1.3) is enabled and disable older insecure protocols like SSL 3.0 and TLS 1.0/1.1.

Business Impact: This is an informational finding confirming the server supports secure encryption for protecting sensitive data during transmission.

3. Vulnerability Name: TLS ALPN Supported Protocol Enumeration
Severity: INFO
Plugin: 84821

Description:

The remote host supports the TLS ALPN (Application-Layer Protocol Negotiation) extension. The scan enumerates the protocols supported by the server during the TLS handshake.

Solution:
Ensure that only necessary and secure protocols are enabled and disable unused or outdated protocols.

Business Impact:
Although informational, this may reveal supported protocols, which attackers could use for reconnaissance and understanding server configuration

4. Vulnerability Name: TCP/IP Timestamps Supported

Plugin: 25220

Description:

The remote host implements TCP timestamps as defined in RFC1323. This feature can sometimes allow the system uptime of the remote host to be calculated.

Solution:

Disable TCP timestamps in the operating system or firewall configuration if they are not required.

Business Impact:

Although informational, attackers may use timestamp information to estimate system uptime and assist in reconnaissance activities.

5.Vulnerability Name: Strict Transport Security (STS) Detection
Severity: INFO
Plugin: 42822 Description:

The remote web server implements Strict Transport Security (STS). This security feature forces browsers to use HTTPS instead of HTTP, helping prevent users from accidentally connecting through insecure connections.

Solution:
Ensure HTTP Strict Transport Security (HSTS) is properly configured with secure settings and appropriate policies.

Business Impact:
This is an informational finding indicating that the server enforces secure HTTPS communication, which helps protect users from downgrade attacks and improves web security.

6. Vulnerability Name: SSL Root Certification Authority Certificate Information
Severity: INFO
Plugin: 94761 Description:
The remote service uses an SSL certificate chain that contains a self-signed root Certification Authority certificate at the top of the chain.

Solution:

Ensure that the use of this root Certification Authority certificate complies with the organization's security policies and trusted certificate standards.

Business Impact:
Although informational, improper management of root certificates may a ect trust relationships and secure communication, which could lead to potential security risks.

7. Vulnerability Name: SSL Certificate Chain Contains Certificates Expiring Soon
Severity: INFO
Plugin:83298 Description:
The remote host has an SSL certificate chain containing one or more certificates that will expire soon. If not renewed before the expiration date, secure connections may fail.

Severity: INFO Plugin:

Solution:
Renew the SSL certificates before their expiration date to ensure continuous secure communication.

Business Impact:
Expired certificates may cause service disruption and loss of secure connectivity, potentially a ecting user access and trust.

8. Vulnerability Name: Shor's Harvest Now Decrypt Later
Severity: INFO
Plugin: 298387

Description:
The scan reports network services that may be vulnerable to future attacks using quantum computing. Algorithms such as RSA, Di ie-Hellman, and Elliptic Curve Di ieHellman could potentially be broken by Shor's Algorithm, allowing attackers to collect encrypted data now and decrypt it later when powerful quantum computers become available.

Solution:

Use quantum-resistant cryptographic algorithms and update encryption methods to futureproof cryptographic security.

Business Impact:
Although informational, sensitive data encrypted today could be captured and decrypted in the future, posing long-term confidentiality risks.

9. Vulnerability Name: Service Detection

Severity: INFO
Plugin: 22964

Description:
The scan identified the remote service by analyzing the banner information or HTTP response messages. It detected that a web server is running on port 80 (TCP) on the target host.

Solution:

Limit unnecessary service exposure and configure servers to hide or minimize banner information to reduce service fingerprinting.

Business Impact:
Although informational, exposed service details may help attackers identify running services and plan targeted attacks.

10. Vulnerability Name: Remote Services Not Using Post-Quantum Ciphers
Severity: INFO
Plugin: 277650

Description:
The scan reports that the remote services do not support post-quantum cryptographic ciphers. Traditional encryption methods such as RSA and Di ie-Hellman rely on mathematical problems that could potentially be broken by quantum computing algorithms like Shor's Algorithm.

Solution:
Evaluate and plan migration to post-quantum cryptography (PQC) or quantumresistant algorithms when they become widely supported.

Business Impact:
Although informational, encrypted data transmitted today could be at risk in the future if quantum computers are able to break current cryptographic algorithms.

11. Vulnerability Name: OS Fingerprints Detected
Severity: INFO
Plugin: 209654

Description:
The scan gathered operating system fingerprints from the remote host using multiple probes such as TCP/IP, SMB, HTTP, NTP, and SNMP. These fingerprints help identify the possible operating system running on the target system.

Solution:

Limit unnecessary service exposure and configure systems to reduce information disclosure through network responses.

Business Impact:
Although informational, OS fingerprinting may allow attackers to identify the target system and search for known vulnerabilities related to that operating system

Severity: INFO Plugin:

12. Vulnerability Name: Nessus SYN Scanner Detection
Severity: INFO

Plugin: 11219
Description:
This plugin performs a SYN “half-open” port scan to identify open ports on the target system. It is faster and less intrusive than a full TCP connect scan but can still reveal active network services.

Solution:
Implement firewall rules and IP filtering to restrict unauthorized port scanning and limit exposure of open ports.

Business Impact:
Although informational, open port information may allow attackers to identify running services and attempt targeted attacks.

13. Vulnerability Name: Nessus Scan Information
Severity: INFO
Plugin: 19506
Description:
This plugin provides information about the scan configuration, including the plugin set version, scanner type, Nessus engine version, port scanning methods, scanned port range, scan date, and scan duration.

Solution:

No action required. This plugin only provides scan-related information for reporting and analysis purposes.

Business Impact:
This is an informational entry that helps security teams review scan details and understand how the vulnerability assessment was performed.

14. Vulnerability Name: Host Fully Qualified Domain Name (FQDN) Resolution

Severity: INFO
Plugin: 12053

Description:
The scan was able to resolve the Fully Qualified Domain Name (FQDN) of the remote host, mapping the system's IP address to its domain name.

Solution:

Restrict unnecessary DNS information exposure and ensure proper network configuration to limit information disclosure.

Business Impact:
Although informational, exposed domain name details may assist attackers in network reconnaissance and target identification.

15. Vulnerability Name: Additional DNS Hostnames
Severity: INFO
Plugin: 46180
Description:
The scan discovered additional DNS hostnames that point to the same remote host. These hostnames may represent name-based virtual hosts (vhosts) configured on the web server.

Solution:
Review discovered hostnames and re-scan them individually if required to identify services or vulnerabilities associated with each virtual host.

Business Impact:
Although informational, exposed hostnames may reveal additional websites or services hosted on the same server, which attackers could use for reconnaissance.

16. Vulnerability Name: SSL Perfect Forward Secrecy Cipher Suites Supported
Severity: INFO
Plugin: 57041
Description:
The remote host supports SSL cipher suites that provide Perfect Forward Secrecy (PFS). This ensures that even if the server's private key is compromised in the future, previously captured encrypted tra ic cannot be decrypted.

Solution:

Ensure strong PFS-supported cipher suites such as those using Di ie-Hellman or Elliptic Curve Di ie-Hellman are properly configured and weak ciphers are disabled.

Severity: INFO Plugin:

Business Impact:
This is an informational finding indicating that the server supports strong encryption mechanisms, improving the security of encrypted communications.

17. Vulnerability Name: SSL Cipher Suites Supported

Severity: INFO

Plugin:21643

Description

The remote host supports a set of SSL/TLS cipher suites that are used to encrypt communications between the client and the server. This plugin identifies which cipher suites are accepted by the remote service during the SSL/TLS handshake process.

Cipher suites define the algorithms used for key exchange, encryption, and message authentication during secure communication sessions. Reviewing supported cipher suites helps administrators ensure that only secure and modern cryptographic algorithms are enabled.

Relevant concept:

- Cipher suite

Solution

No remediation is required as this is an informational finding.

However, administrators should periodically review the supported cipher suites and ensure that:

- Only strong cipher suites are enabled.
- Weak or deprecated cipher suites (such as RC4, DES, or NULL ciphers) are disabled.
- The server is configured to use secure TLS protocols and modern encryption standards.

Business Impact

This finding is informational and provides visibility into the SSL/TLS encryption configuration of the server. Proper management of cipher suites ensures that secure encryption mechanisms are used, helping protect sensitive data during transmission.

18. Vulnerability Name: SSL Cipher Block Chaining Cipher Suites Supported

Severity: INFO

Plugin: 70544

Description

The remote host supports SSL/TLS cipher suites that operate in Cipher Block Chaining (CBC) mode. CBC is a block cipher mode used to encrypt data in SSL/TLS communications.

In CBC mode, each block of plaintext is XORed with the previous ciphertext block before encryption. This provides stronger security than simple block encryption methods such as Electronic Codebook (ECB). However, if CBC mode is improperly implemented or used with outdated TLS configurations, it may expose systems to certain cryptographic attacks.

Relevant concepts:

- Cipher Block Chaining
- Electronic Codebook

Solution

No immediate remediation is required since this is an informational finding.

However, administrators should ensure that:

Severity: INFO Plugin:

- Modern cipher suites such as AES-GCM or ChaCha20-Poly1305 are preferred.

- Older CBC-based cipher suites are gradually deprecated if stronger alternatives are available.
- The server supports modern TLS versions (TLS 1.2 or TLS 1.3) with secure configurations.

Business Impact

This finding is informational and indicates that the server supports CBC-mode cipher suites for encrypted communication. While CBC is more secure than ECB, improper configuration or use with outdated TLS versions could introduce potential security risks. Proper cipher suite management helps maintain strong encryption practices.

19. Vulnerability Name: SSL Certificate Information

Severity: INFO

Plugin:10863

Description

The scan connects to SSL-enabled ports on the remote host and extracts the X.509 certificate details used for secure communications. This information helps review the SSL/TLS certificate configuration and validity.

Relevant concept:

- X.509

Solution

No remediation is required as this is an informational finding.
Administrators should ensure that the SSL certificate is valid, issued by a trusted Certificate Authority, and renewed before expiration.

Business Impact

This finding provides visibility into the SSL/TLS certificate configuration, helping ensure secure encrypted communication between the server and clients.

20. Vulnerability Name: SSL Certificate Expiry – Future Expiry

Severity: INFO
Plugin:42981
Description

The SSL certificate used by the remote service is valid but will expire in the future. Monitoring certificate expiration helps ensure that secure services continue to operate without interruption.

Relevant concept:

- X.509

Solution

Renew or replace the SSL certificate before its expiration date to avoid service disruption and maintain secure communications.

Business Impact

If the certificate expires, users may receive security warnings and encrypted services may become untrusted, potentially a ecting system availability and user trust.

21. Vulnerability Name: SSL / TLS Versions Supported

Severity: INFO
Plugin: 56984
Description

The scan identifies the SSL and TLS protocol versions supported by the remote service for encrypted communications. This information helps assess whether the server supports secure and modern TLS versions.

Relevant concept:

- Transport Layer Security

Solution

No remediation is required as this is an informational finding. Administrators should ensure that secure TLS versions (TLS 1.2 or TLS 1.3) are enabled and older, insecure versions are disabled.

Business Impact

This finding provides visibility into the encryption protocols supported by the server, helping organizations verify that secure communication standards are in place.

22. Vulnerability Name: SSL/TLS Recommended Cipher Suites

Severity: INFO
Plugin: 156899

Description

The remote host supports SSL/TLS cipher suites that are not recommended for secure configurations. Security best practices suggest enabling only modern and strong cipher suites to ensure secure encrypted communications.

Relevant concept:

- Cipher suite

Solution

Configure the server to allow only recommended cipher suites, such as AES-GCM or ChaCha20-Poly1305, and disable discouraged or weak cipher suites.

Business Impact

Using non-recommended cipher suites may weaken encryption and increase the risk of cryptographic attacks. Restricting the configuration to modern cipher suites improves the overall security of SSL/TLS communications.

23. Vulnerability Name: TLS Supported Groups

Severity: INFO
Plugin: 277654

Description

The scan identifies the TLS supported groups (elliptic curves and key exchange groups) used by the remote service during TLS connections. This helps review the cryptographic parameters used for secure communication.

Relevant concept:

- Elliptic Curve Cryptography

Solution

No remediation is required as this is an informational finding. Administrators should ensure that secure and modern cryptographic groups are enabled while deprecated or weak groups are disabled.

Business Impact

This finding provides visibility into the TLS cryptographic configuration of the server, helping ensure that secure key exchange mechanisms are used for encrypted communications.

24. Vulnerability Name: Web Server No 404 Error Code Check

Severity: INFO

Plugin:10386

Description

The remote web server does not return the standard 404 Not Found error when a request is made for a non-existent file. Instead, it may return another page such as a site map, search page, or authentication page.

Solution

Configure the web server to return the correct 404 error code for requests to nonexistent resources.

Business Impact

Improper error responses may reduce vulnerability scanning accuracy and make it di icult to correctly identify missing resources on the server.

25. Vulnerability Name: Web Server robots.txt Information Disclosure

Severity: INFO
Plugin:10302
Description

The remote web server contains a robots.txt file used to instruct web crawlers about which directories should not be indexed. However, the file may reveal sensitive or restricted directories that could be discovered by attackers.

Relevant concept:

- robots.txt

Solution

Review the contents of the robots.txt file and remove references to sensitive directories. Use Robots META tags or implement proper access control mechanisms to protect restricted resources.

Business Impact

Exposure of sensitive directories through the robots.txt file may provide attackers with information that could assist in identifying hidden resources or potential attack targets on the web server.

26. Vulnerability Name: HTTP Server Type and Version Disclosure

Severity: INFO
Plugin: 10107
Description

The scan identified the type and version of the remote web server. This information may reveal details about the server software running on the system.

Relevant concept:

- Hypertext Transfer Protocol

Solution

Configure the web server to hide or limit server version information in HTTP response headers where possible.

Business Impact

Disclosure of server type and version may help attackers identify known vulnerabilities associated with specific server software, potentially assisting in targeted attacks.

27. Vulnerability Name: HyperText Transfer Protocol (HTTP) Information

Severity: INFO
Plugin: 24260
Description

The scan provides general information about the remote HTTP service, including the protocol version and whether features such as HTTP Keep-Alive are enabled. This test is informational and does not indicate a security issue.

Relevant concept:

- Hypertext Transfer Protocol

Solution

No remediation is required as this is an informational finding. Administrators may review HTTP configuration settings to ensure secure and optimal server operation.

Business Impact

This finding provides basic information about the HTTP configuration of the server, helping administrators understand how the web service is configured.

Stage 3

Title

Enforce Least-Privilege Access through Identity-Aware, Application-Specific Access Policies using Zscaler Private Access (ZPA)

Overview

Modern organizations require secure access to internal applications while preventing unauthorized access. Traditional access methods such as Virtual Private Network provide broad network access once users authenticate, which can increase security risks.
ZPA follows the Zero Trust model and provides secure application-level access. It verifies identity, device posture, application risk, and contextual information before granting access, ensuring that users only access the resources required for their role.

Identity

Identity-based access ensures that only authenticated and authorized users can access applications. ZPA integrates with identity providers to verify user credentials and enforce authentication methods such as multi-factor authentication. Access is granted based on user roles and permissions.

Device Posture

Device posture verification checks whether the device accessing the application meets the organization’s security policies. The system may verify operating system updates, antivirus status, and security compliance before allowing access.

Application Risk

Applications are categorized based on their importance and sensitivity. Critical applications require stronger authentication and stricter access policies, while less sensitive applications may have standard access controls.

Context-Aware Access

Context-aware access evaluates factors such as location, login time, device type, and network environment. If suspicious activity is detected, the system may request additional verification or deny access.

Conclusion

Stage 1

Understanding common vulnerabilities through the OWASP Top 10 helps developers identify and mitigate major web application security risks.

Stage 2

Using Nessus for vulnerability scanning helps detect system weaknesses and provides insights into security configurations.

Stage 3

Implementing Zscaler Private Access strengthens security by enforcing identity-based access and limiting user permissions according to the principle of least privilege.

Future Scope

Stage 1

Future improvements may include automated vulnerability detection and secure coding practices integrated into development processes.

Stage 2

Continuous vulnerability scanning and real-time monitoring can further enhance system security.

Stage 3

Zero Trust solutions like ZPA can be expanded to secure cloud environments, remote users, and hybrid infrastructures.

Topics Explored

OWASP Top 10

Vulnerability Scanning

Cybersecurity Awareness

Identity Access Control

Zero Trust Security Model

Tools Explored

Zscaler Private Access (ZPA)

Nessus

OWASP

Web Security Testing Tools